8.Configuring User Management and Role-Based Access Control (RBAC)

1. Aim

To configure user management, assign custom roles, and implement Role-Based Access Control (RBAC) in the Patient Appointment & Scheduling Management application built using Zoho Creator to protect appointment information and restrict form/report permissions according to user roles (CEO/Admin, Doctor, Patient).

2. Objective

- Learn how Zoho Creator manages users, permissions, invitations, and role hierarchies.
- Create and define custom Doctor and Patient roles with their own permission profiles.
- Enforce component-level restrictions on Forms, Reports, and Pages.
- Configure patient-specific report filtering using the logged-in user identity and automate patient email entry.

3. Tools Required

- Zoho Creator account with application administrator permissions.
- Patient Appointment & Scheduling Management application.
- Forms: Appointment_Booking_Form, Doctors.
- Reports: All_Appointments_List, All Doctors, My_Appointments, Appointment_Status_Kanban.
- Page: Clinic_Command_Center_Page.

4. Procedure

Step 1: Defining Roles in Zoho Creator

Establish the functional roles required for secure patient appointment management.

1. Open the Patient Appointment & Scheduling Management application in Zoho Creator builder mode.
2. Navigate to Settings > User Permissions > Roles.

3. Create or verify the role hierarchy shown in the application:
   a. CEO (Admin): Supervises the application and manages clinic operations, doctors, and appointments.
   b. Doctor: Accesses authorized appointment schedules and patient appointment status information.
   c. Patient: Books appointments and accesses only their own appointment information.

Step 2: Configuring Component-Level Permissions

Set up access, view, edit, and delete permissions for the application modules.

1. Open Settings > User Permissions > Permissions.
2. Create or open the custom profiles Doctor_Permission and Patient_Permission.
3. In Doctor_Permission, grant access to the Appointment_Booking_Form and selected appointment reports required for the doctor workflow. Allow editing of the appointment-status report only when necessary; keep Delete, View all, and Modify all disabled.
4. In Patient_Permission, permit access to the Appointment_Booking_Form for new bookings. Disable edit, delete, unrestricted report access, and administrator-only pages. Grant View to the patient-specific My_Appointments report once its filtering is verified.
5. Keep Clinic_Command_Center_Page restricted from patients. Configure Doctors / All Doctors visibility only for information appropriate to the assigned role. Click Update to save each profile.

Step 3: Implementing Record-Level Criteria Filtering

To restrict the appointment records displayed to an individual patient:

1. In Design, create a List Report named My_Appointments based on Appointment_Booking_Form.
2. Open the report > Filter. Choose Email Address as the field and equals as the operator.
3. Configure a dynamic value for the currently logged-in user, rather than a literal email or a fixed string. The intended Deluge-style condition is:

   Email_Address == zoho.loginuserid

4. Save the filter. Verify with separate signed-in test users that each patient can see only their own appointments, and that no other accessible report exposes unrelated records.
5. The Email_Address field must be linked securely to the authenticated patient; a report filter alone must not be treated as complete access control.

Step 4: Creating the Email Autofill Workflow

To fill the patient email automatically when a new appointment form loads:

1. Navigate to Workflow > Form Workflows and choose New Workflow.
2. Select Appointment_Booking_Form > Created > Load of the form.
3. Name the workflow Auto_Fill_Patient_Email and add a Deluge script action.
4. Enter the following Deluge statements and save the workflow:

```
input.Email_Address = zoho.loginuserid;
disable Email_Address;
```

5. Verify that the workflow is Enabled and confirm that Email Address is filled and non-editable when a signed-in patient opens the form. Apply separate identity controls to staff-assisted bookings.

Step 5: Inviting Users and Assigning Roles

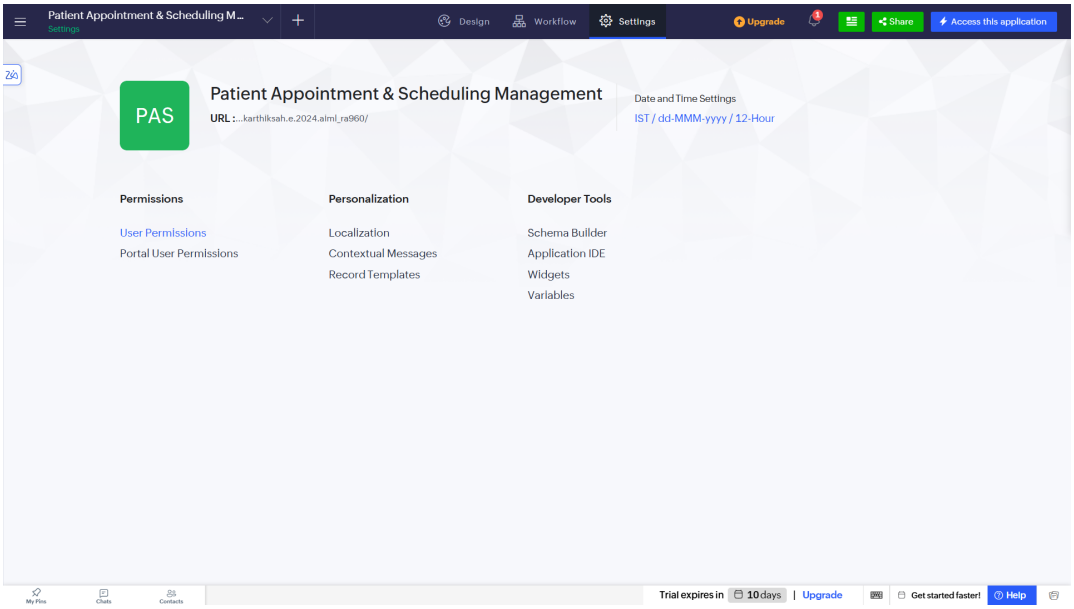
After configuring the permissions and record restrictions, onboard test users into the application.

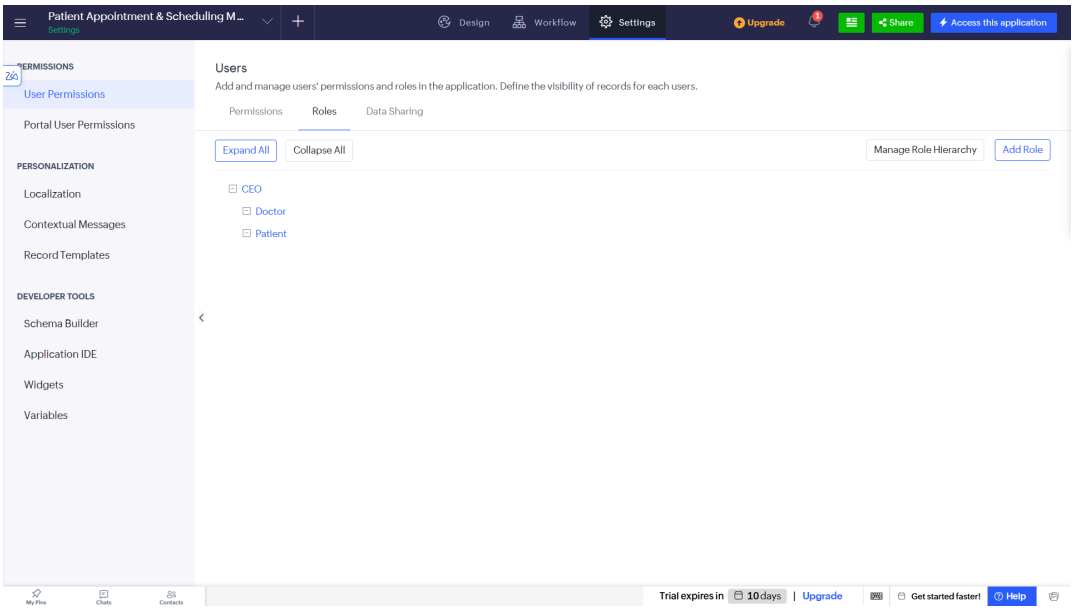
1. Open the application sharing/user management interface (Share or Manage > Users, according to the Creator interface).
2. Choose Add User / Invite User and enter the intended test user email address.
3. Assign Doctor with Doctor_Permission to a doctor test account, or Patient with Patient_Permission to a patient test account.
4. Send the invitation if the plan allows additional users. For portal users, use the separate Portal User Permissions configuration.
5. Log in with each test account and verify that appointment records, reports, and pages are accessible only as authorized.

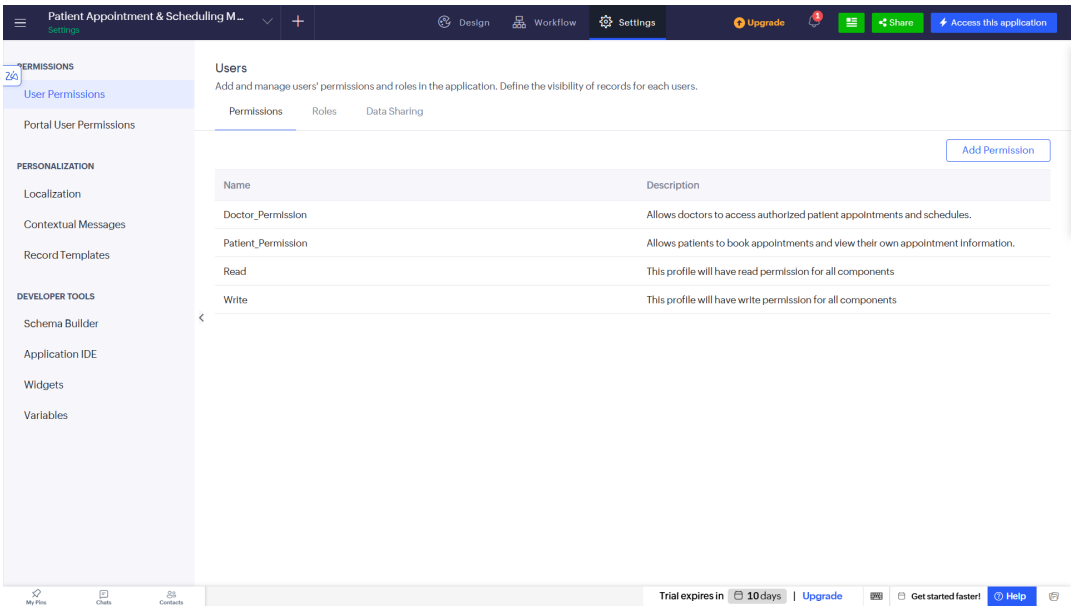
5.Screenshot

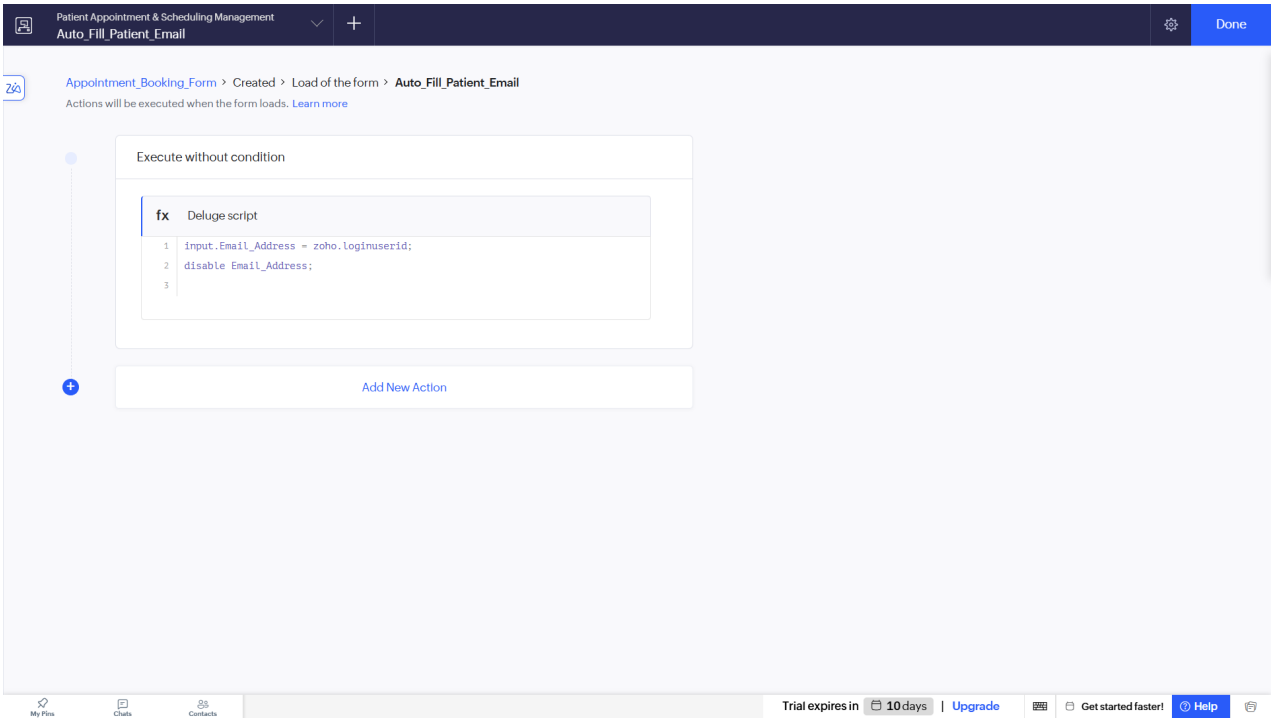
The following screenshots document the application settings, role hierarchy, permission profiles, and enabled email autofill workflow.

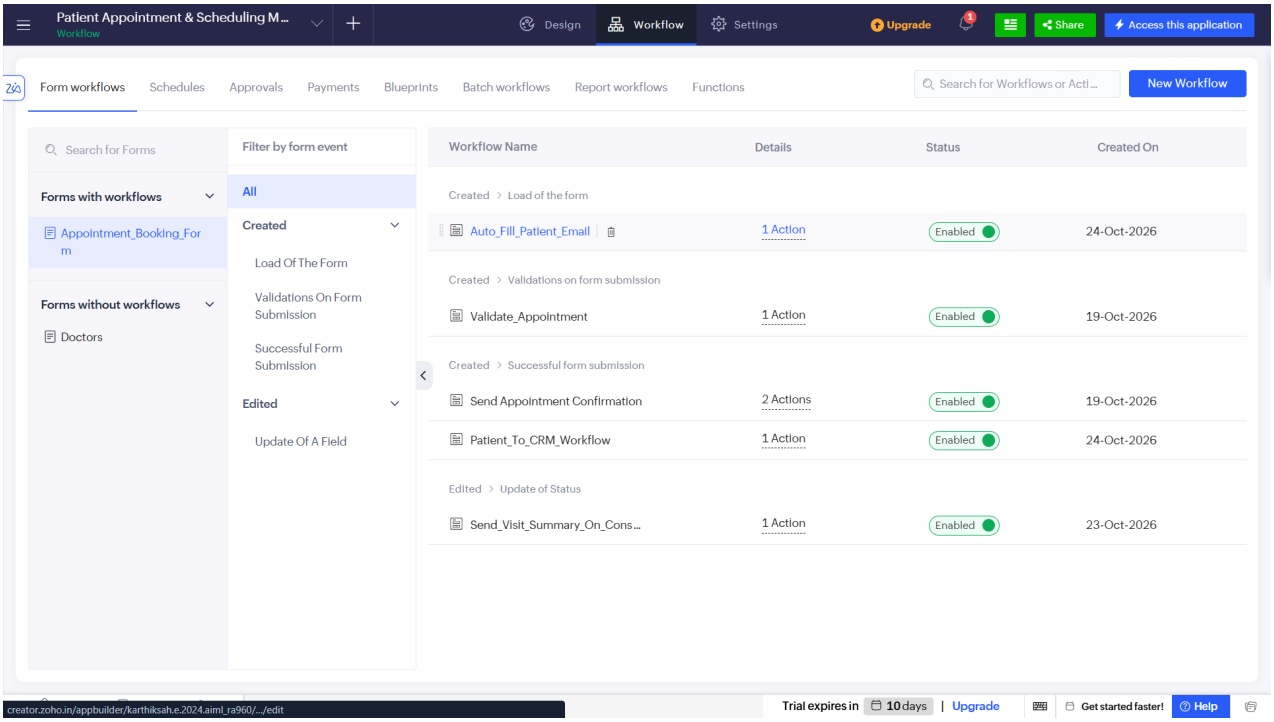
5.Screenshot











6. Result

The Patient Appointment & Scheduling Management application was configured with the CEO, Doctor, and Patient role hierarchy and with Doctor_Permission and Patient_Permission profiles. A patient-specific My_Appointments report was created, and the Auto_Fill_Patient_Email workflow was configured and enabled using zoho.loginuserid. Final verification of record-level privacy and user invitations must be performed using separate test accounts before considering access control fully validated.